

mobiTrace

Plan de Reprise d'Activité

PRA — Procédures de reprise après sinistre

Référence	TRACE-PRA-2026
Version	1.0
Date	08/08/2026
Auteur	Équipe technique mobiTrace / DGFIP

Résumé exécutif

Ce document définit les procédures étape par étape pour reprendre les services mobiTrace après un sinistre majeur, avec un objectif de RTO de 4 heures et RPO de 12 heures.

Il couvre quatre scénarios : corruption de la base de données (S2), compromission de sécurité (S3), sinistre total du serveur TRACE (S4) et perte du serveur NFS (S5). Chaque procédure est accompagnée des commandes exactes à exécuter, d'une check-list de validation et d'un programme de tests annuels.

Avertissement — Ce document contient des procédures techniques sensibles. Ne pas diffuser hors des équipes habilitées. Conserver une copie hors ligne.

1. Objectifs de reprise

1.1 Indicateurs de reprise

Indicateur	Valeur	Définition	Base
RTO	4 heures	Temps max entre sinistre et reprise	Activité non temps-réel
RPO	12 heures	Perte de données maximale tolérée	2 sauvegardes/jour
RTD	30 minutes	Temps de détection du sinistre	Sonde email 08h00 + monitoring
RLO	99 %	Niveau de reprise minimal acceptable	Toutes fonctions sauf impression Zebra

1.2 Scénarios couverts

Scénario	Code	Description	RTO cible
Panne service (Nginx/PostgREST/P	S1	Un ou plusieurs services KO, données intactes	< 30 min → PCI
Corruption base de données	S2	Base corrompue ou inaccessible, serveur OK	< 2h
Compromission de sécurité	S3	Intrusion, ransomware partiel, fuite credentia	< 4h
Sinistre total serveur TRACE	S4	Perte matérielle totale (incendie, vol, panne)	< 4h
Perte serveur NFS	S5	Sauvegardes inaccessibles, serveur TRACE O	< 1h

Le scénario S1 (panne de service) est traité dans le PCI. Le PRA couvre les scénarios S2 à S5, nécessitant une restauration ou une réinstallation.

1.3 Prérequis à la reprise

Avant de démarrer toute procédure PRA, s'assurer de disposer de :

- Accès physique ou SSH root au serveur TRACE (ou à une machine de remplacement)
- Accès SSH au serveur NFS (pour copier les dumps si NFS non monté)
- Les fichiers .deb des paquets mobiTrace (trace-server, trace-backup-client, etc.)
- Une connexion réseau opérationnelle entre les deux machines
- Note : le RTO commence à l'heure de détection du sinistre, pas à l'heure de début des travaux

2. Procédure S2 — Corruption de la base de données

Le serveur TRACE fonctionne mais la base parc_mobilier est corrompue ou inaccessible. Les fichiers de sauvegarde NFS sont disponibles.

2.1 Diagnostic préalable (0-15 min)

```
# Vérifier l'état de PostgreSQL
sudo systemctl status postgresql
sudo -u postgres psql -c 'SELECT version();'

# Vérifier l'intégrité de la base (si PostgreSQL démarre)
sudo -u postgres psql -d parc_mobilier -c 'SELECT count(*) FROM mobiliers;'

# En cas d'erreur : noter le message exact pour le rapport d'incident
```

2.2 Restauration depuis le dump NFS (15-90 min)

La restauration utilise le script interactif trace_restore.sh qui gère automatiquement la synchronisation du secret JWT.

```
# Vérifier que le montage NFS est actif
df -h /mnt/savetrace || sudo mount /mnt/savetrace

# Lister les sauvegardes disponibles (les plus récentes en premier)
ls -lt /mnt/savetrace/trace_backup_*.dump | head -10

# Lancer la restauration interactive
# Le script : liste les dumps, demande une confirmation OUI,
# restaure, puis synchronise le secret JWT automatiquement
sudo /usr/local/bin/trace_restore.sh
```

Le script trace_restore.sh gère automatiquement la synchronisation du secret JWT entre la base restaurée et /etc/trace-api.conf, puis redémarre trace-api.

2.3 Vérification post-restauration (90-120 min)

```
# Vérifier que tous les services sont actifs
systemctl is-active postgresql trace-api nginx

# Test fonctionnel : login (remplacer par vos credentials admin)
curl -sk -c /tmp/cookie.txt \
  -H 'Content-Type: application/json' \
  -d '{"email":"admin@dgfip.fr","password":"<mot_de_passe>"}' \
  https://localhost/api/rpc/login

# Test consultation données
curl -sk -b /tmp/cookie.txt 'https://localhost/api/mobiliers?limit=5'

# Vérifier la cohérence (comparer avec les chiffres avant sinistre)
sudo -u postgres psql -d parc_mobilier \
  -c 'SELECT count(*) FROM mobiliers; SELECT max(date_saisie) FROM mobiliers;'
```

3. Procédure S3 — Compromission de sécurité

Suspicion ou confirmation d'une intrusion, d'un accès non autorisé ou d'un ransomware partiel. Priorité : préserver les preuves, isoler, puis restaurer.

3.1 Isolation immédiate (0-15 min)

```
# Option 1 : Bloquer l'accès externe (conserver l'accès SSH admin)
sudo iptables -I INPUT -p tcp --dport 443 -j DROP
sudo iptables -I INPUT -p tcp --dport 80 -j DROP

# Option 2 : Arrêter uniquement Nginx (SSH reste ouvert)
sudo systemctl stop nginx

# IMPORTANT : NE PAS redémarrer, NE PAS effacer de logs avant préservation
```

3.2 Préservation des preuves (15-45 min)

```
# Copier les logs avant toute action corrective
INC=/root/incident_$(date +%Y%m%d)
mkdir -p $INC
sudo cp -r /var/log/nginx/ $INC/nginx_logs/
sudo journalctl -u trace-api --since '7 days ago' > $INC/trace-api.log
sudo journalctl -u postgresql --since '7 days ago' > $INC/postgresql.log
sudo -u postgres psql -d parc_mobilier \
    -c 'SELECT * FROM audit_logs ORDER BY date_action DESC LIMIT 500;' \
    > $INC/audit_logs.txt
# Notifier le RSSI DGFIP avec ces éléments avant toute action corrective
```

3.3 Rotation des secrets et réinitialisation (45-90 min)

```
# 1. Rotation du secret JWT (invalide toutes les sessions actives)
NEW_JWT=$(tr -dc 'A-Za-z0-9_-' < /dev/urandom | head -c 48)
sudo -u postgres psql -d parc_mobilier \
    -c "UPDATE auth.secrets SET value = '$NEW_JWT' WHERE key = 'jwt_secret';"
sudo sed -i "s|^jwt-secret = .*|jwt-secret = \"$NEW_JWT\"|" /etc/trace-api.conf

# 2. Réinitialiser les mots de passe des comptes suspects
sudo -u postgres psql -d parc_mobilier -c \
    "SELECT public.reinitialiser_mdp('email@suspect.fr', 'NouveauMDP!2026');"

# 3. Redémarrer les services
sudo systemctl restart trace-api nginx fail2ban
```

3.4 Décision : restaurer depuis sauvegarde ?

Si l'analyse des audit_logs révèle des modifications de données non autorisées, une restauration depuis le dernier dump sain est nécessaire (suivre la procédure S2 §2). Sinon, le service peut être réouvert après rotation des secrets.

- Données non altérées → rotation des secrets suffisante → réouvrir le service
- Données altérées → restaurer depuis le dernier dump antérieur à l'intrusion
- Périmètre inconnu → maintenir l'isolation et contacter le RSSI DGFIP

4. Procédure S4 — Sinistre total du serveur TRACE

La machine principale est perdue (panne irréparable, incendie, vol). Objectif : reconstruire mobiTrace sur une nouvelle machine et restaurer depuis les dumps NFS. RTO cible : 4 heures.

PHASE 0 — Évaluation et provisionnement — 0-30 min

Effort : ★☆☆☆ Impact : ★★★★★

Confirmer la perte totale du serveur. Provisionner une machine de remplacement.

- Machine de remplacement : Debian 13 (Trixie), ≥ 4 Go RAM, ≥ 50 Go disque
- Configurer la même adresse IP que l'ancien serveur (DHCP/DNS si nécessaire)
- Vérifier l'accès SSH root opérationnel sur la nouvelle machine
- Vérifier la connectivité réseau vers le serveur NFS : ping <IP_NFS>

PHASE 1 — Réinstallation des paquets — 30 min-1h30

Effort : ★☆☆☆ Impact : ★★★★★

```
# Sur la nouvelle machine Debian 13 :
# 1. Copier les paquets .deb depuis une source sûre (clé USB, dépôt interne)
# Les paquets sont dans le dépôt mobiTrace : build/*.deb

# 2. Installer dans l'ordre :
sudo apt install ./trace-server_1.0.0_all.deb          # installation principale
# !! NOTER les credentials admin affichés à la fin de l'installation !!
sudo apt install ./trace-backup-client_1.0.0_all.deb  # monte le NFS
sudo apt install ./trace-zebra-printer_1.0.0_all.deb  # optionnel

# 3. Vérifier que le NFS est monté
df -h /mnt/savetrace && ls /mnt/savetrace/trace_backup_*.dump | head -5
```

PHASE 2 — Restauration des données — 1h30-2h30

Effort : ★☆☆☆ Impact : ★★★★★

```
# Lancer la restauration interactive
# Le script liste les dumps NFS et gère la synchronisation JWT automatiquement
sudo /usr/local/bin/trace_restore.sh

# -> Choisir le dump le plus récent (max 12h de perte selon RPO)
# -> Taper OUI pour confirmer
# -> Le script restaure et synchronise automatiquement le secret JWT
# puis redémarre trace-api
```

PHASE 3 — Vérification et validation — 2h30-3h30

Effort : ★☆☆☆ Impact : ★★★★★

```
# Tests de validation complète
systemctl is-active postgresql trace-api nginx fail2ban

# Test authentification admin
curl -sk -c /tmp/c.txt -H 'Content-Type: application/json' \
  -d '{"email":"admin@...","password":"..."}' \
```

```
https://localhost/api/rpc/login

# Vérifier la cohérence des données
sudo -u postgres psql -d parc_mobilier -c '
    SELECT count(*) AS nb_mobiliers    FROM mobiliers;
    SELECT count(*) AS nb_utilisateurs FROM utilisateurs;
    SELECT max(date_saisie) AS derniere_saisie FROM mobiliers;'

# Test depuis un poste agent (vérifier le certificat SSL si régénéré)
```

Si le certificat SSL a été régénéré, les agents verront une alerte SSL à la première connexion (certificat auto-signé). Les informer en amont.

5. Procédure S5 — Perte du serveur NFS

Le serveur NFS est indisponible mais le serveur TRACE fonctionne. Les sauvegardes planifiées échouent silencieusement.

5.1 Impact immédiat

- Les sauvegardes automatiques échouent (trace_backup.sh retourne une erreur)
- La sonde mobitrace_backup_survey.sh enverra une ALERTE CRITIQUE à 08h00 le lendemain
- Les données en base sont intactes, l'application continue de fonctionner
- Le RPO se dégrade : chaque heure sans sauvegarde augmente la fenêtre de perte potentielle

5.2 Mitigation immédiate — Sauvegarde locale temporaire

```
# Sauvegarde locale d'urgence (hors NFS)
DATE=$(date +%Y-%m-%d_%H-%M-%S)
sudo -u postgres pg_dump -Fc -d parc_mobilier \
    -f /var/backups/trace_local_${DATE}.dump
echo "Sauvegarde locale : /var/backups/trace_local_${DATE}.dump"

# Planifier des sauvegardes locales temporaires toutes les 2h
# (supprimer ce cron dès que NFS est restauré)
echo '0 */2 * * * postgres /usr/bin/pg_dump -Fc -d parc_mobilier \
    -f /var/backups/trace_local_$(date +%Y%m%d_%H%M).dump' \
    | sudo tee /etc/cron.d/trace_backup_local
```

5.3 Restauration du serveur NFS

- Réinstaller trace-backup-server_1.0.0_all.deb sur la machine NFS
- Vérifier que /var/nfs/backupTRACE est recréé (droits 700, nobody:nogroup)
- Remonter le NFS côté serveur TRACE : sudo mount /mnt/savetrace
- Copier les sauvegardes locales temporaires vers NFS
- Supprimer le cron local temporaire : sudo rm /etc/cron.d/trace_backup_local

6. Check-list de validation post-reprise

À compléter et signer avant toute communication de reprise aux utilisateurs.

6.1 Check-list technique

#	Vérification	Résultat	Validé par
1	postgresql actif : systemctl is-active postgresql	OK / KO	
2	trace-api actif : systemctl is-active trace-api	OK / KO	
3	nginx actif : systemctl is-active nginx	OK / KO	
4	fail2ban actif : systemctl is-active fail2ban	OK / KO	
5	Authentification admin fonctionnelle (POST /api/rpc/login)	OK / KO	
6	Consultation mobiliers (GET /api/mobiliers?limit=1)	OK / KO	
7	Secret JWT synchronisé (/etc/trace-api.conf à jour)	OK / KO	
8	Montage NFS actif (df -h /mnt/savetrace)	OK / KO	
9	Dernière sauvegarde NFS présente et récente	OK / KO	

10	Cohérence données (count mobiliers cohérent avant/après)	OK / KO	
11	Interface web accessible depuis un poste agent	OK / KO	
12	Rôle agent : modification de statut mobilier fonctionnelle	OK / KO	
13	Rôle lecteur : consultation seule (pas d'écriture)	OK / KO	
14	Fail2Ban : pas d'IPs légitimes bannies	OK / KO	
15	Rapport d'incident rédigé et transmis au RSSI	OK / KO	

6.2 Signature et approbation

Rôle	Nom / Prénom	Signature / Date
Responsable technique		
Responsable PCA		
RSSI DGFIP (si incident sécurité)		

7. Plan de tests et maintien en condition

7.1 Programme de tests annuels

Test	Fréquence	Durée	Objectif	Responsable
Test restauration S2 (dump NFS vers b	Trimestriel	2h	Valider l'intégrité des dumps NF	Équipe technique
Test PRA S4 complet (bare metal, mac	Annuel	4h	Valider RTO=4h de bout en bou	Équipe technique
Test coupure NFS (S5) — sauvegarde l	Semestriel	30 min	Valider la mitigation sauvegard	Équipe technique
Test communication de crise	Annuel	1h	Valider arbre d'appel et modèle	Responsable PCA

7.2 Fiche de test — Restauration trimestrielle

À remplir après chaque test trimestriel de restauration.

Champ	Valeur
Date du test	
Dump restauré (nom du fichier)	
Durée de la restauration	
Nombre de mobiliers restaurés	
Nombre d'utilisateurs restaurés	
Anomalies constatées	
Actions correctives	
Validé par	

7.3 Mise à jour du PRA

Ce document doit être mis à jour dans les cas suivants :

- Après tout sinistre réel (retour d'expérience, révision des procédures)
- Après toute évolution de l'architecture (nouveau composant, changement de machine)
- Après tout changement de version majeure des paquets trace-server
- Annuellement, même sans évolution (révision formelle et validation)

Document généré automatiquement par generate_pra_pdf.py (dépôt mobiTrace). Pour toute question : equipe.support@dgfip.finances.gouv.fr